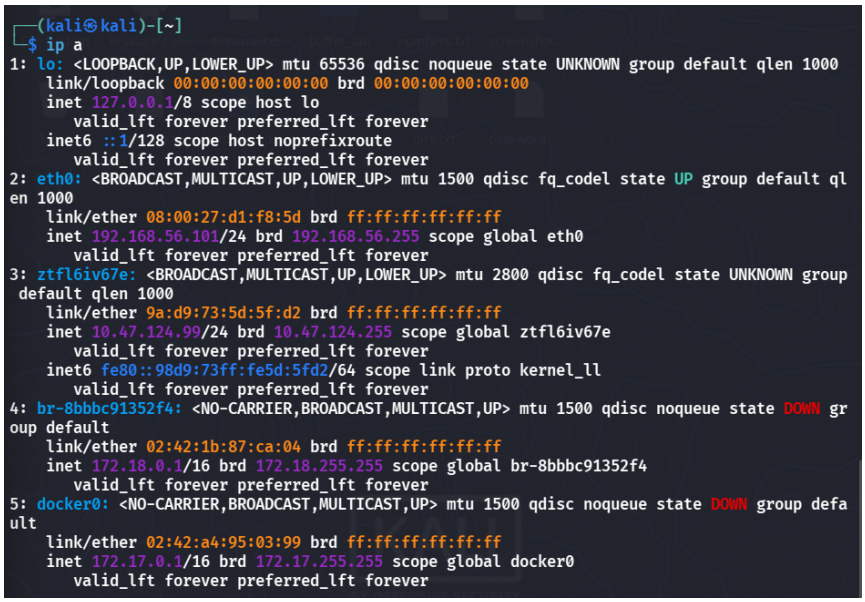
Metasploitable 2 Network Security Lab Report

Section 1: Metasploitable Lab Setup & Network Verification

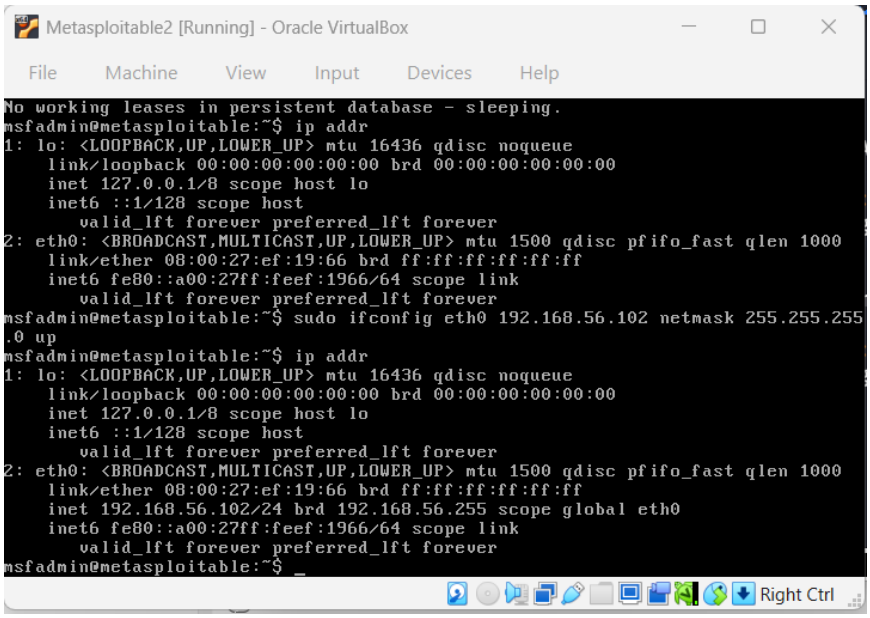
1.1 IP Configuration

Attacker Machine (Kali Linux):



Static IP assignment for Kali

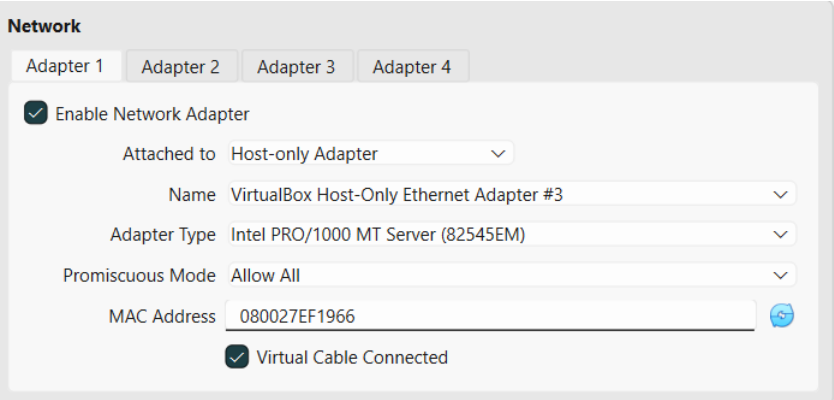
Metasploitable 2 Machine:



Static IP assignment for Metasploitable

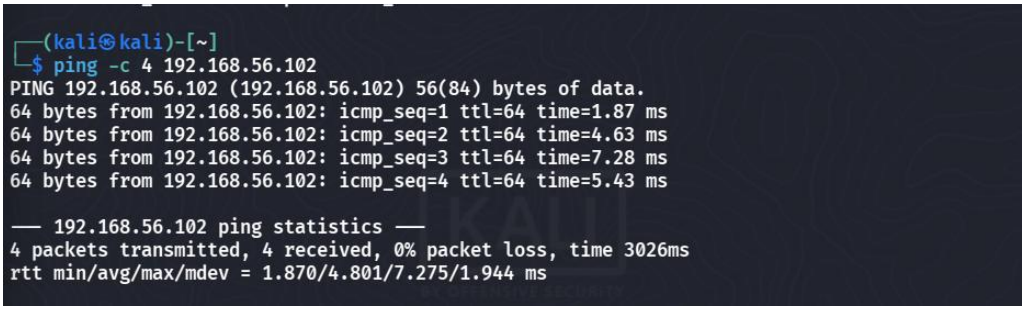
1.2 Network Configuration

Network Mode Used: (Host-Only)



1.3 Connectivity Test (Ping)

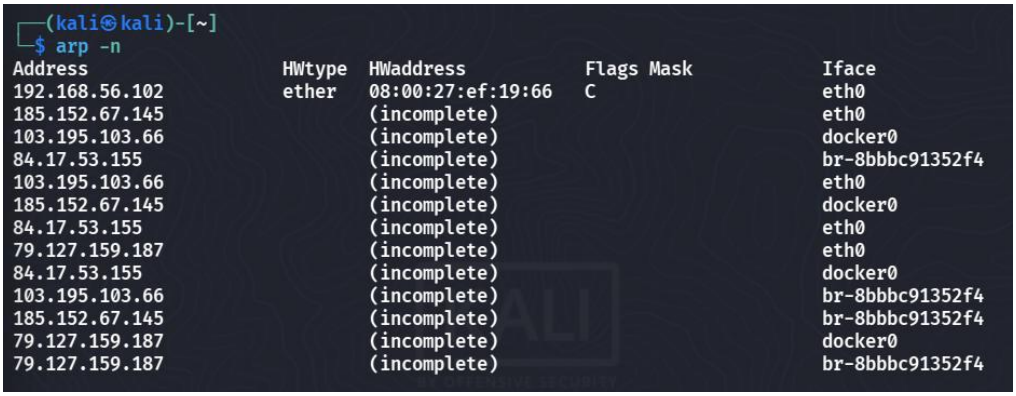
ping 192.168.56.101



Ping test confirming connectivity between VMs

1.4 ARP Table

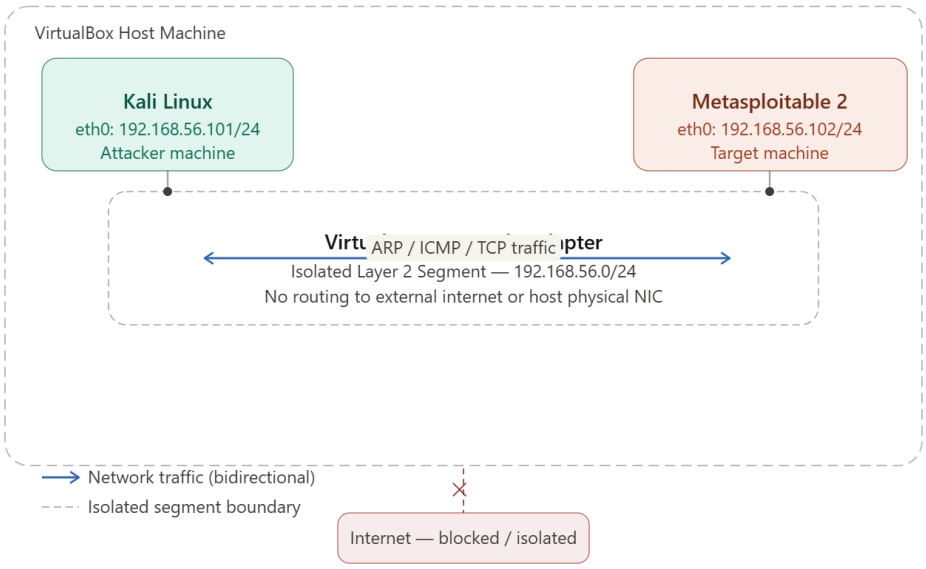
arp -a



ARP table showing target MAC address

1.5 Network Diagram

The diagram illustrates the logical connection between the attacker (Kali Linux) and the target (Metasploitable 2). Both virtual machines are interfaced through a VirtualBox Host-Only Adapter, creating an isolated Layer 2 segment that prevents any traffic from leaking to the external internet or the host's physical network.



Logical network topology showing the isolated Host-Only environment for Kali and Metasploitable 2

Explanation

- **Why Metasploitable 2 is reachable:**

Both machines are connected to the same network, allowing direct communication between them.

- **How ARP resolves traffic:**

ARP translates IP addresses into MAC addresses. The attacker machine sends a request asking for the MAC address of the target IP, and the target responds with its MAC address.

- **Why this network mode is appropriate:**

This setup isolates the lab environment from the internet, making it safe for testing and experimentation.

Section 2: Host Discovery & Network Enumeration

2.1 Subnet Scan

nmap -sn 192.168.56.0/24

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.56.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-05 15:42 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0057s latency).
MAC Address: 08:00:27:EF:19:66 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.101
Host is up.
Nmap done: 256 IP addresses (2 hosts up) scanned in 37.53 seconds
```

2.2 OS Detection & Enumeration

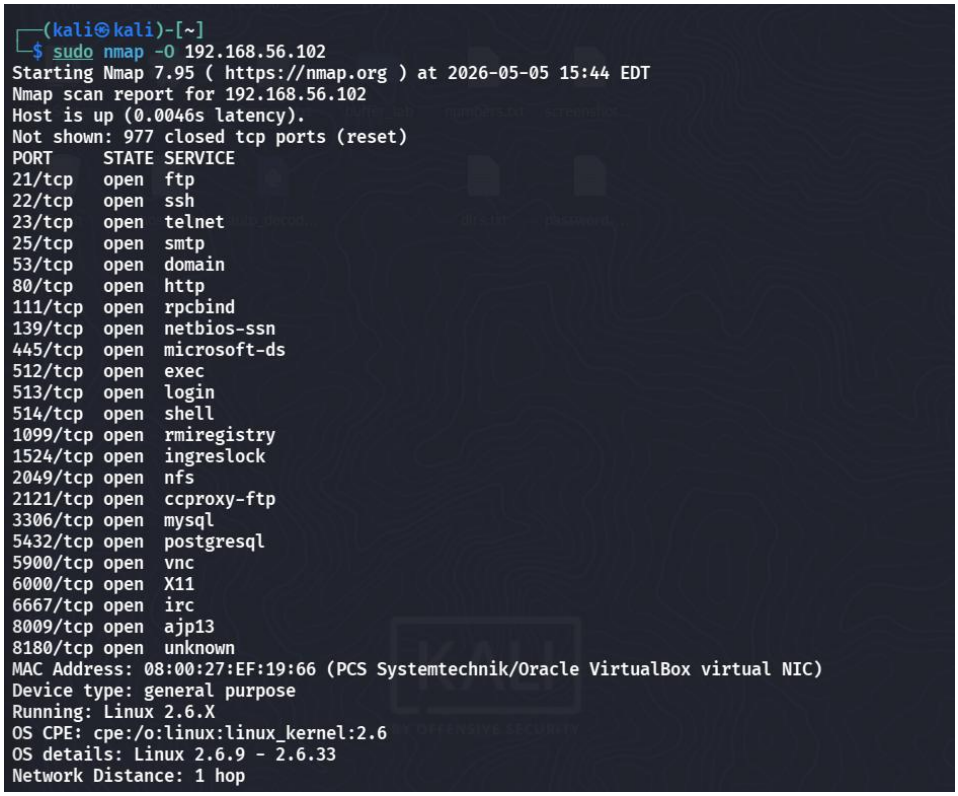
nmap -A 192.168.56.101

```
┌──(kali㉿kali)-[~]
└─$ nmap -A 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-06 17:34 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0079s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.56.101
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_ssl-date: 2026-05-06T16:17:34+00:00; -5h17m36s from scanner time.
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS
, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrPro
vinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
| sslv2:
|   SSLv2 supported
|   ciphers:
```

Nmap -A scan results for services and versions

2.3 OS Fingerprinting

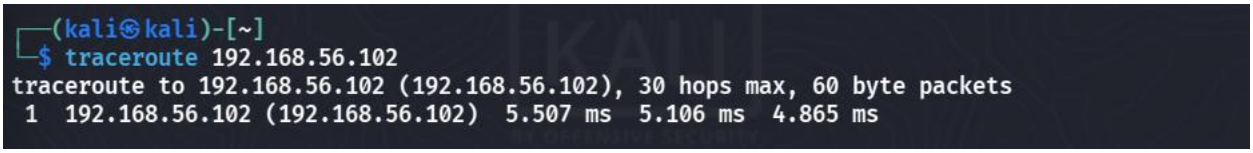
nmap -O 192.168.56.101



Nmap OS detection and fingerprinting

2.4 Traceroute

traceroute 192.168.56.101



Traceroute results confirming a direct network path between VMs

Explanation

- **How Metasploitable was identified:**

The target was identified through a subnet scan that revealed active hosts, followed by detailed scanning.

- **OS fingerprinting behavior:**

Nmap analyzes responses from the target system and compares them to known signatures to estimate the operating system.

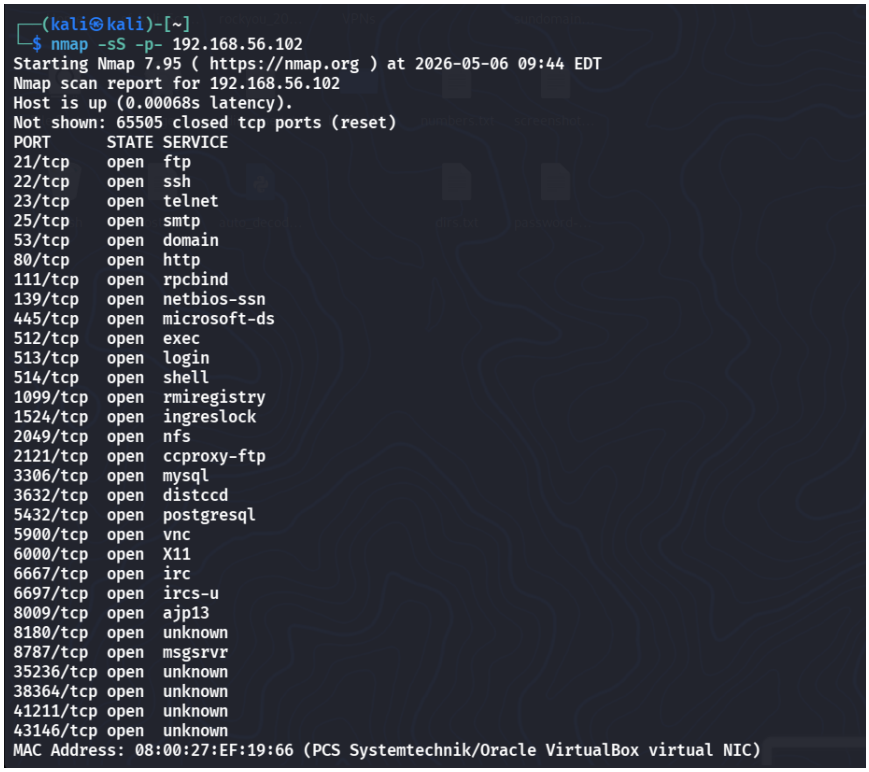
- **Traceroute observations:**

The result showed a direct connection with minimal hops, indicating both machines are on the same network.

Section 3: Port Scanning & Service Enumeration

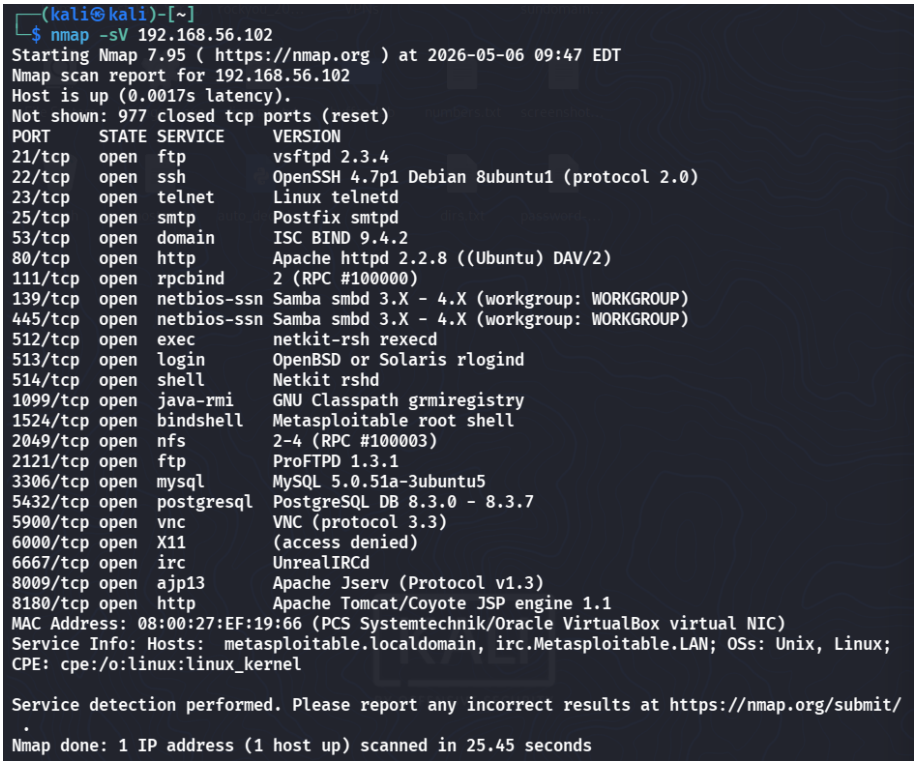
3.1 Full TCP Scan

nmap -sS -p- 192.168.56.101



3.2 Service Version Detection

nmap -sV 192.168.56.101

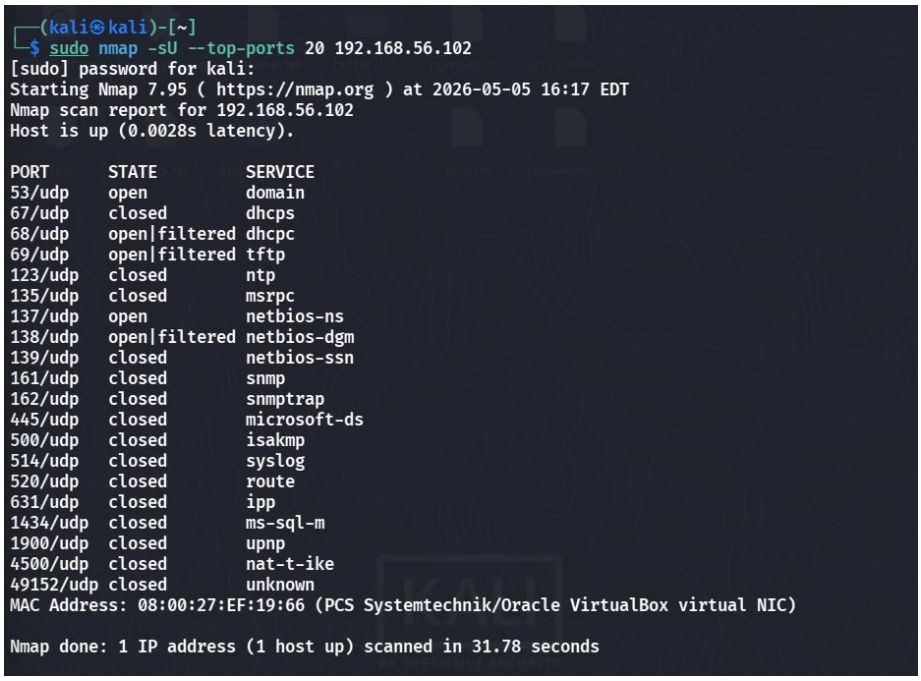


```
┌──(kali㉿kali)-[~]
└─$ nmap -sV 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-06 09:47 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0017s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:EF:19:66 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux;
CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
 .
Nmap done: 1 IP address (1 host up) scanned in 25.45 seconds
```

3.3 UDP Scan

nmap -sU --top-ports 20 192.168.56.101



```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sU --top-ports 20 192.168.56.102
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-05 16:17 EDT
Nmap scan report for 192.168.56.102
Host is up (0.0028s latency).

PORT      STATE         SERVICE
53/udp    open          domain
67/udp    closed        dhcps
68/udp    open|filtered dhcpc
69/udp    open|filtered tftp
123/udp   closed        ntp
135/udp   closed        msrpc
137/udp   open          netbios-ns
138/udp   open|filtered netbios-dgm
139/udp   closed        netbios-ssn
161/udp   closed        snmp
162/udp   closed        snmptrap
445/udp   closed        microsoft-ds
500/udp   closed        isakmp
514/udp   closed        syslog
520/udp   closed        route
631/udp   closed        ipp
1434/udp  closed        ms-sql-m
1900/udp  closed        upnp
4500/udp  closed        nat-t-ike
49152/udp closed        unknown
MAC Address: 08:00:27:EF:19:66 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 31.78 seconds
```

3.4 Port and Service Table

Port	Protocol	Service	Version
21	TCP	FTP	vsftpd 2.3.4
22	TCP	SSH	OpenSSH 4.7p1
23	TCP	Telnet	Linux telnetd
25	TCP	SMTP	Postfix smtpd
80	TCP	HTTP	Apache httpd 2.2.8
445	TCP	NetBIOS	Samba smbd 3.X
3306	TCP	MySQL	MySQL 5.0.51a
5432	TCP	PostgreSQL	PostgreSQL DB 8.3.0

Only open ports were included in this table as they represent active services that could be exploited.

Explanation

- **Why Metasploitable exposes many services:**

It is intentionally designed with vulnerabilities for testing and educational purposes.

- **TCP vs UDP difference:**

TCP is connection-oriented and reliable, while UDP is faster but does not guarantee delivery.

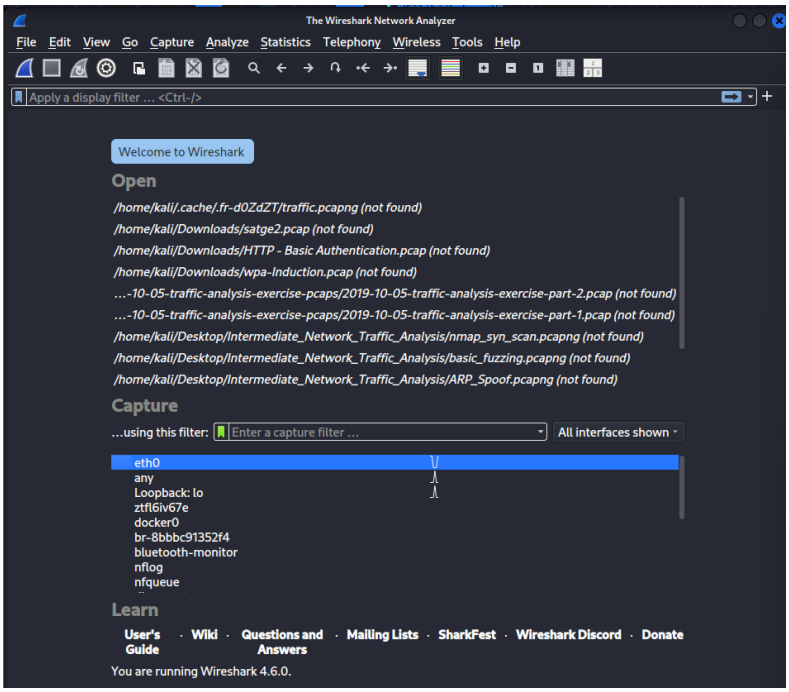
- **Dangerous services:**

Examples include FTP, Telnet, and SMB due to weak security or lack of encryption.

Section 4: Packet Capture & Traffic Analysis

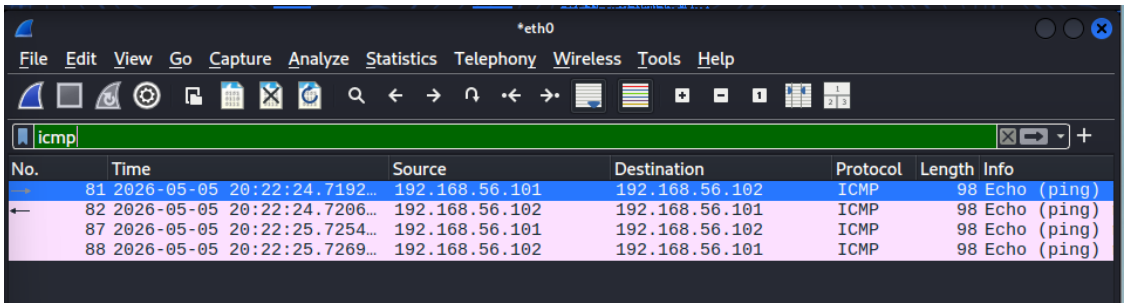
4.1 Packet Capture

Tool Used: Wireshark



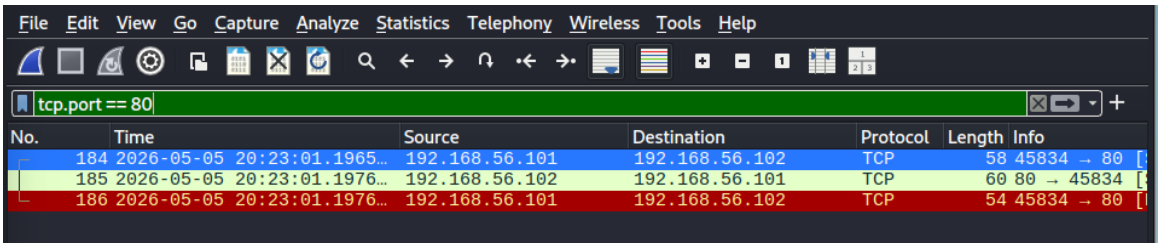
4.2 ICMP Traffic

icmp



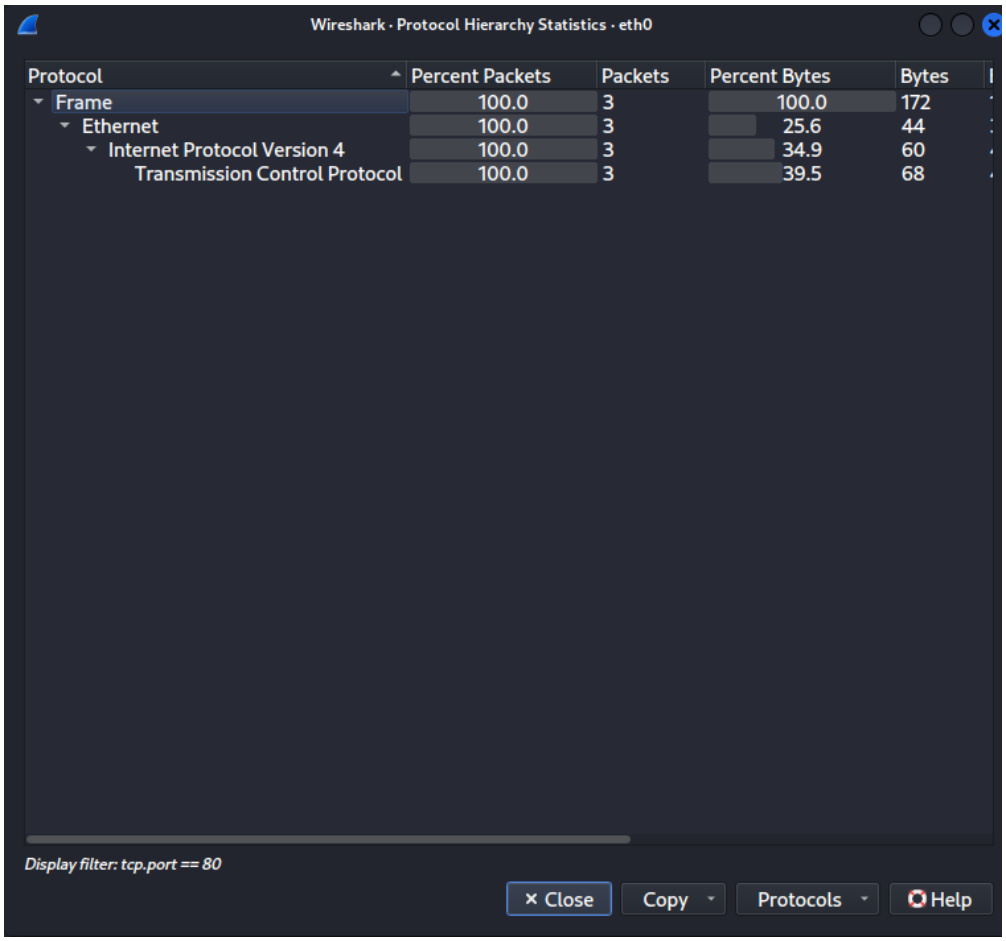
icmp to capture ping traffic between attacker and target

4.3 TCP 3-Way Handshake



Wireshark capture of the TCP 3-way handshake (SYN, SYN-ACK, ACK) sequence

4.4 Protocol Hierarchy



Wireshark Protocol Hierarchy filtered for TCP Port 80, showing the encapsulation layers from Ethernet to the Transport layer

Explanation

- **Protocols observed:**

ICMP, TCP, and ARP were observed during the capture.

- **TCP handshake explanation:**

The handshake consists of SYN, SYN-ACK, and ACK steps to establish a connection.

- **How scanning appears in captures:**

Scanning generates a large number of packets targeting multiple ports.

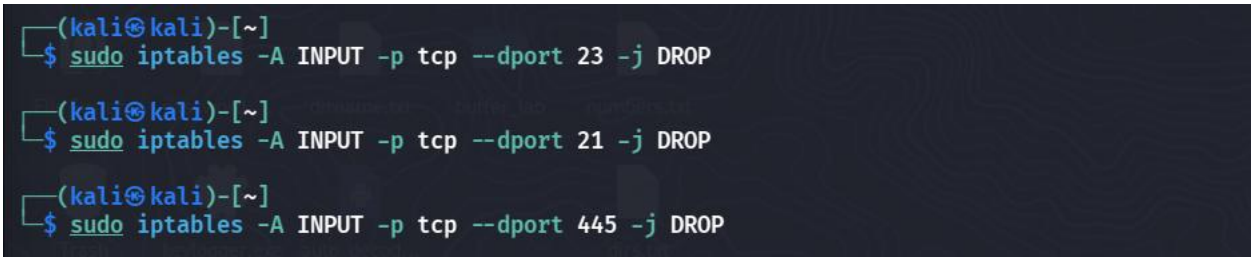
Section 5: Network Security & Defensive Design

5.1 Risky Services

- FTP (21): No encryption; credentials sent in cleartext. Vulnerable to sniffing and backdoors.
- Telnet (23): Obsolete and unencrypted. Entire session (login/commands) is visible to attackers.
- HTTP (80): Outdated Apache version. High risk of web exploits and unauthorized access.
- SMB (445): Prone to Remote Code Execution (RCE). Allows file system takeover.

5.2 Firewall Rules

Example:



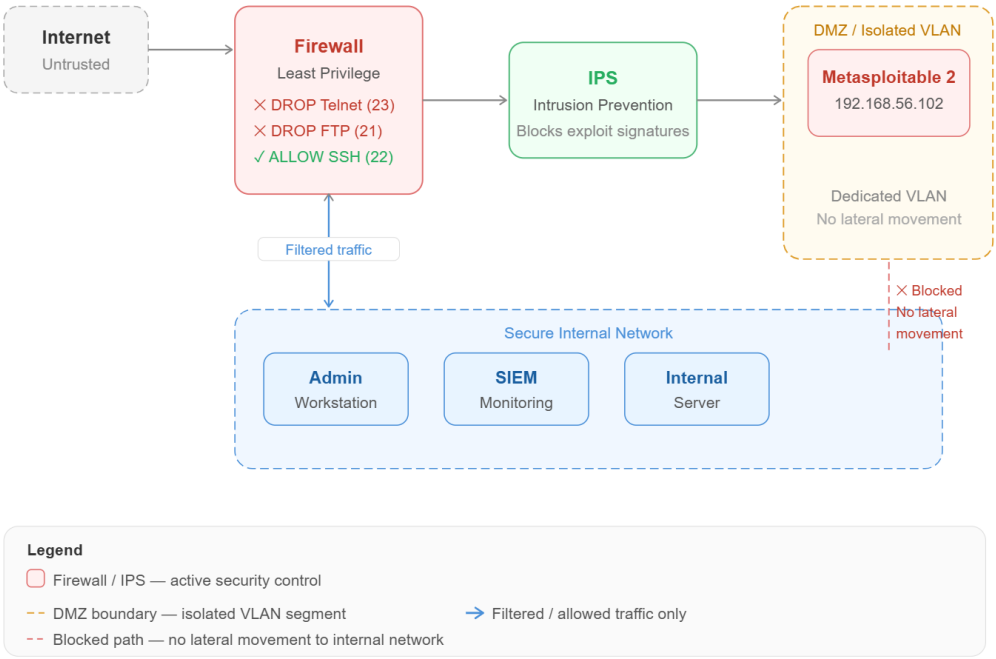
Iptables rules to block ports 21, 23, and 445

```
┌──(kali㉿kali)-[~]
└─$ sudo iptables -L -n -v
Chain INPUT (policy ACCEPT 144 packets, 27792 bytes)
 pkts bytes target     prot opt in     out     source               destination
    0     0 DROP       tcp  --  *      *       0.0.0.0/0            0.0.0.0/0           tcp
dpt:23
    0     0 DROP       tcp  --  *      *       0.0.0.0/0            0.0.0.0/0           tcp
dpt:23
    0     0 DROP       tcp  --  *      *       0.0.0.0/0            0.0.0.0/0           tcp
dpt:21
    0     0 DROP       tcp  --  *      *       0.0.0.0/0            0.0.0.0/0           tcp
dpt:445
```

Verification of active DROP policies

5.3 Secure Network Design

This design implements a Defense-in-Depth strategy by placing the vulnerable Metasploitable 2 instance within an Isolated DMZ. A central Firewall/IPS layer acts as a security gateway, enforcing strict traffic policies to drop insecure protocols (FTP, Telnet, SMB) while inspecting permitted packets for malicious signatures. This architecture ensures that even in the event of a breach, the threat is contained, preventing any Lateral Movement toward the secure internal network.



Secure Network Diagram with DMZ and Firewall

5.4 Traffic Monitoring

Tools:

- Wireshark
- IDS systems
- Logs

By combining active prevention (Firewall) with continuous monitoring (Wireshark & IDS), we create a Proactive Defense posture that ensures all unauthorized attempts are logged and analyzed for future hardening.

Explanation

- **Why Metasploitable is insecure:**

It is intentionally built with vulnerabilities for practice.

- **How firewall rules reduce exposure:**

They block access to unnecessary or dangerous services.

- **Correct placement in secure networks:**

It should be placed in an isolated or internal network, not exposed to the internet.

Conclusion

In conclusion, this lab emphasizes that network security is a continuous process. Implementing a robust defense mechanism requires not only blocking known threats through firewalls but also maintaining constant visibility through traffic analysis and logging to mitigate emerging vulnerabilities.